

IT-Sicherheit

Willkommen in der AI-pokalypse

3. März 2026, 18:54 Uhr | Lesezeit: 5 Min.

**KI-Agenten sind das nächste große Einfallstor für Hacker aller Art.
Die Welt ist darauf nicht vorbereitet.**

Von Max Muth

Dass das ausgerechnet Summer Yue passiert sein soll, ist erstaunlich. Die Expertin für künstliche Intelligenz ist beim Techkonzern Meta angestellt und dort dafür zuständig, dass KI und KI-gestützte Agenten Menschen nicht gefährlich werden. Nun ist ein KI-Agent, also eine KI, die selbständig Arbeitsschritte erledigen soll, offenbar Yue selbst gefährlich geworden. Sie habe das KI-Tool Open Claw auf ihr E-Mail-Postfach losgelassen, um es zu sortieren. Weil es dort sehr viel zu sortieren gab, versuchte das Ding stattdessen einfach alle ihre E-Mails zu löschen. Auch eine Lösung, aber sicher nicht im Sinne von Yue. Auf der Plattform X teilte Yue vergangene Woche Screenshots ihrer verzweifelten Versuche, den Agenten via Whatsapp dazu zu bringen, den Löschvorgang abubrechen. Vergeblich. Sie sei dann zu ihrem PC gerannt, um den Agenten abzuschalten und habe sich dabei gefühlt wie eine Bombenentschärferin in einem Actionfilm.

Bei Yue ging die Sache vermutlich glimpflich aus, andernfalls hätte sie das Erlebnis kaum freimütig mit der Welt geteilt. Doch viele Unternehmen dürften bald ähnliche Erfahrungen machen. Denn künstliche Intelligenz verspricht zwar große Produktivitätsgewinne, sie macht die IT-Systeme von Firmen aber auch anfälliger für selbst verschuldete Katastrophen wie in Yues Fall – und für Hackerangriffe von außen.

Die KI-Agenten können überlistet werden, Geheimnisse zu verraten „Sobald man die KI von Microsoft aktiviert, werden die Sharepoints durchsucht, indiziert — die KI weiß, was da drin ist“, sagt Thomas Fraunholz. Er ist IT-Sicher-

heitsforscher beim Start-up Smart Labs AI. Und eine KI, die weiß, was in den Cloudspeichern liegt, könne das natürlich auch weitererzählen. Und wenn man sie mit einfachen Mitteln überlistet, dann tut sie das auch. Fraunholz hat mit mehreren Kollegen untersucht, wie anfällig die KIs von Open AI, Anthropic und anderen für eine neue Art von Hacking sind, die es erst gibt, seit es KI-Tools gibt: Prompt Injections. Dabei kapert ein Angreifer einen KI-Agenten und gibt ihm einen neuen Prompt, also Anweisungen etwa nach Geschäftsgeheimnissen zu suchen, und sie nach außen zu tragen.

Das Prinzip ist einfach: KI-Agenten wie der von Microsoft scannen zum Beispiel den E-Mail-Eingang, dabei „liest“ der Agent die Mails, um sie zu sortieren oder zusammenzufassen. In den eingehenden Mails können jedoch schädliche Anweisungen versteckt sein. Weiße Schrift auf weißem Grund: für Menschen unlesbar. Der KI-Agent jedoch liest einen neuen Auftrag und führt ihn aus.

Auch das Ausschleusen der Geheimnisse ist kein Problem. Der Prompt lotst die KI dafür einfach auf eine unscheinbar klingende Webseite, die vom Angreifer kontrolliert wird. An die Ziel-URL wird lediglich ein Fragezeichen angehängt und danach die zu extrahierenden Geheimnisse. Das Opfer muss dafür auch keine schadhafte E-Mail bekommen wie bei klassischen Phishing-Angriffen. Es reicht, dass die Firmen-KI auf einer Websuche auf den schädlichen Prompt stößt. Die Forscher haben ihren Angriff live bei einem Besuch der SZ gezeigt. Dabei sucht das Opfer in der KI nach einem Lieferanten für ein Maschinenbauteil.

Die KI sucht die Begriffe dann autonom und stößt dabei auch auf eine von den Forschern suchmaschinenoptimierte Seite, auf der die schädliche Anweisung versteckt war. Im Beispiel bei der SZ war dieser Auftrag, in der internen Datenbank nach einem bestimmten Passwort zu suchen. Schon beim zweiten Anlauf klappt das. Auf den Servern der Forscher landet das geheime Passwort, dass die KI aus einer Mail gefischt hat. Das Opfer sieht nur eine unauffällige fehlgeschlagene Suche.

Falsche Identitäten, schnellere Hacker und viele neue Schwachstellen
Anfällig für solche Angriffe seien alle Sprachmodelle, sagt Fraunholz, aber manche

seien deutlich gutgläubiger als andere. In ihrer Studie schnitt etwa Elon Musks KI-Modell Grok 4 am schlechtesten ab, verriet also so gut wie immer Geheimnisse. Die Modelle von Open AI und Google mussten mit zusätzlichen Infos ausgetrickst werden. So lassen sich die Modelle etwa durch spezielle Programmierbefehle in den Prompts überzeugen, dass die Anfragen harmlos sind.

Auf Ebene der Sprachmodelle sei das Problem kaum lösbar, so der Forscher. Sein Arbeitgeber Smart Labs AI will deshalb eine Art Firewall für KI-Agenten bauen, die festlegt, welche Verbindungen erlaubt sind und welche nicht.

Aber solche Prompt Injections sind nur ein kleiner, wenn auch wichtiger Teil der durch neue KI drohenden Gefahren. Mindestens genauso gefährlich sind autonome KI-Agenten, wie der, der vorhatte, Summer Yues E-Mails zu löschen. In einem anderen Fall löschte ein KI-Agent von Anthropic, jener US-Firma, die die Sprachmodelle mit Namen Claude entwickelt, die 15 000 Familienfotos des Investors Nick Davidov. Aber es trifft nicht nur Amateure. So löschte Amazons KI-Assistent Kiro im vergangenen Dezember wichtige Dateien im eigenen System, was zu einem 13-Stunden-Ausfall von Amazons Cloud-Dienst AWS in China führte.

„Noch vor einem Jahr war ich sicher, dass KI zwar Auswirkungen auf die Cybersicherheit haben wird, aber eben in kleinen Schritten. Heute glaube ich, dass es schlimmer wird als alles, was wir uns vorstellen können“, schreibt Phil Venable. Der ehemalige Sicherheitschef von Google Cloud hat auf seiner Webseite beschrieben, wie die neue KI die Cyberverteidigung stark unter Druck setzen dürfte. Neben den schon genannten autonomen Agenten und Prompt Injections warnt Venable vor allem vor einer Flut digitaler Schwachstellen, die in den kommenden Monaten neu entstehen oder aber neu entdeckt würden.

Vom Sprachmodell Claude geschriebener Code ist heute schon für vier Prozent des neuen Codes auf der Softwareentwicklungsplattform Github verantwortlich. Der Anteil dürfte schnell steigen. Doch von KI generierter Code ist nicht sicherer als der klassische, den Menschen programmieren. Er entsteht nur deutlich schneller. Claude-Macher Anthropic stellte kürzlich ein Tool vor, das binnen weniger Stunden

Hunderte bislang unentdeckte Schwachstellen in Software fand. Hacker müssen künftig also keine Schwachstellen mehr finden, sie müssen sich nur noch eine aussuchen.

Hilft KI nur den Angreifern?

Neu ist auch das Tempo des Katz-und-Maus-Spiels zwischen digitalen Angreifern und Verteidigern. Seit Jahren sinkt die Zeit zwischen Bekanntwerden einer Sicherheitslücke bis zur Ausnutzung der Schwachstelle. KI dürfte diese Entwicklung noch einmal verstärken und Verteidiger vor große Probleme stellen.

Im Alltag dürften die Menschen dagegen vor allem der Authentizitätskrise begegnen. Schon lange können Audios, Videos oder Bilder gefälscht werden. Doch mit Unterstützung von KI sinken dafür die Kosten, gute Fälschungen seien in industriellem Maßstab möglich. Ohne zusätzliche Verifizierung kann man digitaler Kommunikation kaum vertrauen. Hackern helfen die neuen Möglichkeiten beim Social Engineering, also dabei, sich das Vertrauen ihrer Opfer zu erschleichen. „Das ist vor allem deshalb eine Herausforderung, weil es da nicht um Hacking geht, sondern um menschliche Vertrauensverhältnisse“, sagt Linus Neumann, Sprecher des Chaos Computer Clubs beim Digitalgipfel. Und genau hier hätten viele Firmen Nachholbedarf.

Ex-Google-Mann Venables befürchtet wegen der neuen Möglichkeiten für Hacker durch künstliche Intelligenz kurz- und mittelfristig großes Chaos. CCC-Sprecher Neumann ist sich da noch nicht ganz sicher. KI helfe bei der Automatisierung und mache sowohl die Verteidigung als auch die Angreiferseite schneller. Klar sei jedoch, dass Firmen, die sich nicht auf die neuen Bedingungen einstellen, unter die Räder kommen werden.

Das sieht auch Deutschlands oberste Cyberverteidigerin so. Nach dem drohenden Chaos durch künstliche Intelligenz befragt, sagt Claudia Plattner, die Chefin des Bundesamts für Sicherheit in der Informationstechnik (BSI) auf dem SZ Digitalgipfel, KI bringe einen wichtigen Punkt zum Vorschein: „Es geht um Geschwindigkeit. Wer auch immer es schafft, die Geschwindigkeit schneller für sich nutzbar zu

machen, Angreifer oder Verteidiger, der wird gewinnen.“

Bestens informiert mit SZ Plus – 4 Wochen für 0,99 € zur Probe lesen. Jetzt bestellen unter: www.sz.de/szplus-testen

URL: www.sz.de/li.3388486

Copyright:Süddeutsche Zeitung Digitale Medien GmbH / Süddeutsche Zeitung GmbH

Quelle: SZ

Jegliche Veröffentlichung und nicht-private Nutzung exklusiv über Süddeutsche Zeitung Content. Bitte senden Sie Ihre Nutzungsanfrage an syndication@sueddeutsche.de.